

CHALLENGE 3: Logs mancanti per operazioni critiche

Descrizione:

Senza un sistema di logging adeguato, non è possibile risalire a chi ha eseguito operazioni sensibili (es. cambio ruolo, creazione articoli, accessi).

Questo viola i principi di accountability e non-repudiation, rendendo impossibile indagare su attacchi o abusi.

Esempio di rischio:

Un attaccante potrebbe promuoversi ad admin tramite CSRF (Challenge 2) e non lasciare traccia del suo operato.

Mitigazione

Soluzione implementata:

Ho aggiunto log espliciti per tutte le operazioni critiche:

Creazione/modifica/eliminazione articolo

Cambio ruolo (admin/revisor/writer)

Login/logout

```
local.INFO: RATE LIMITER ATTIVATO - IP: 127.0.0.1  
local.INFO: RATE LIMITER ATTIVATO - IP: 127.0.0.1  
local.INFO: RATE LIMITER ATTIVATO - IP: 127.0.0.1  
local.INFO: RATE LIMITER ATTIVATO - IP: 127.0.0.1  
local.INFO: ARTICOLO CREATO: ID 1, Titolo 'testtt', Autore: diego@admin.com (ID: 8), IP: 127.0.0.1
```

Conclusioni:

Ora ogni azione critica è tracciata, permettendo di identificare utenti, orari e IP in caso di incidente.

